SECURELINK VPN LAB

Research Project | Secure VPN for Remote Access

Encryption & Authentication Plan

Establishing a Secure VPN for Remote Access

Deliverable D2 of 6

Organisation	Research project (lab build)
Author	Kshitij Rajesh Randhire
Version	1.0 (final)
Basis	Lab build on VMware; evidence IDs [E01]-[E38] refer to the evidence screenshot set
Status	Lab documentation. Not certified and not presented as production-ready.

Contents

1 Purpose and scope
2 Cryptographic design
3 PKI as built and revocation
4 Multi-factor authentication
5 Authorization
6 Integrity
7 Non-repudiation
8 Implementation status
Appendix: evidence cited

1 Purpose and scope

This plan records the encryption, certificate and authentication choices I made in the lab, along with the evidence that each one works. Items are labelled Implemented and verified, Implemented but limited, or Recommended, not implemented. No private keys, passwords or TOTP secrets appear here. Server logs are in UTC, and the Kali client clock runs four hours behind UTC.

2 Cryptographic design

Layer	Settings	Evidence
Site-to-site IKE (strongSwan IKEv2)	AES_CBC_256, PRF_HMAC_SHA2_256, HMAC_SHA2_256_128, MODP_2048	[E01]
Site-to-site ESP	AES_CBC-256 with HMAC_SHA2_256_128 (CBC with HMAC, not GCM)	[E01]
Client TLS session (OpenVPN)	TLS 1.3, TLS_AES_256_GCM_SHA384, X25519; server certificate RSA 2048; tls-version-min 1.2	[E05][E10]
Client data channel	AES-256-GCM (cipher and data-ciphers); auth SHA256	[E05][E10]
Control channel protection	tls-crypt	[E10]
Certificate revocation	crl-verify /etc/openvpn/crl/crl.pem; CRL signed sha256WithRSA	[E03][E10]
File integrity check	SHA-256 of a test file	[E17][E18]

The AES-256 requirement of the brief is met on both VPN types. End-to-end here means gateway-to-gateway and client-to-gateway: traffic is encrypted between the two VPN endpoints, not between the user and each internal application.

3 PKI as built and revocation

3.1 PKI as built

Item	As built	Evidence
CA	Single-tier self-signed CA "SecureLink-VPN-CA" (Easy-RSA, OpenSSL 3.0.13), valid 27 Oct 2026 to 24 Oct 2036	[E26]
Server certificate	gw-hq, valid to 29 Jan 2029, EKU serverAuth	[E03]
Issued certificates	gw-hq, gw-branch and one client (remote-user)	[E02]
Key storage	Private keys mode 600	[E02]
CRL	sha256WithRSA, next update 28 Apr 2027	[E03][E26]

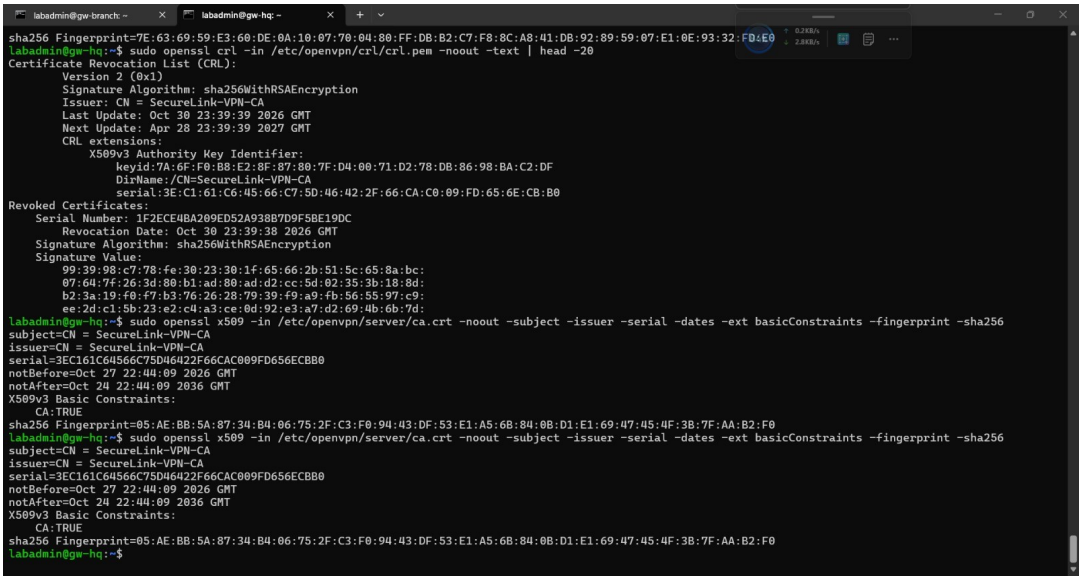


Figure 1. Self-signed root CA certificate and fingerprint [E26]

Implemented but limited: a two-tier PKI (offline root plus issuing CA) was planned but not done. The root CA key therefore sits on the same system that issues certificates. Per-user certificates were not issued; only one client certificate exists.

3.2 Revocation procedure and test

Test certificate: revoke-test, serial 1F2ECE4BA209ED52A938B7D9F5BE19DC [E23]. Sequence observed in the server log [E24]:

Time (UTC)	Event	Evidence
23:37:43	revoke-test connected successfully	[E24]
23:39:38	Certificate revoked and CRL regenerated; serial listed in the CRL	[E23]
23:40:48	New connection attempts rejected with "certificate revoked"	[E24][E25]

Procedure to follow (generic): 1) identify the certificate serial of the user or device; 2) revoke it in the CA; 3) regenerate the CRL; 4) make sure the CRL file is in the location named by crl-verify; 5) confirm that a new connection attempt is rejected and record the time. The lab used Easy-RSA for these steps.

Not tested: cutting off a session that was already established when the certificate was revoked. Until tested, an incident procedure should also include ending the live session by another means.

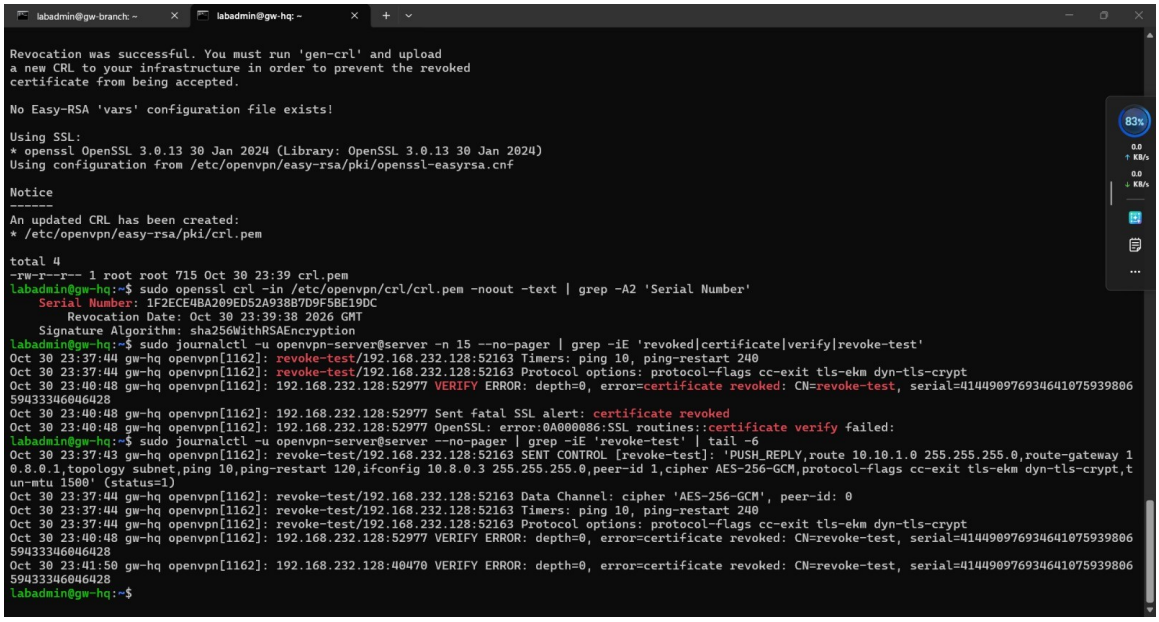


Figure 2. Server log: revoked certificate accepted before revocation, rejected after [E24]

4 Multi-factor authentication

MFA combines something the user has (client certificate) with a time-based one-time password (TOTP). The server uses pam_google_authenticator through /etc/pam.d/openvpn. The user account is vpnuser and the TOTP code is typed at the OpenVPN password prompt [E05][E09]. The code is generated by a free TOTP authenticator app.

Setup step	Note
1	Enroll the user in pam_google_authenticator on gw-hq; the secret is shown once to the user and must never be copied into documents or tickets
2	Add the PAM plugin to the OpenVPN server configuration (PAM plugin present in server.conf [E10]) and point it at the openvpn PAM service [E09]
3	User adds the secret to an authenticator app and types the six-digit code at the password prompt
4	Verify success and failure in auth.log and the client log

Test	Result	Time (UTC)	Evidence
Correct code (1)	Accepted, route pushed	21:36:37	[E07][E09]
Correct code (2)	Accepted	21:41:36	[E07][E09]
Wrong code	AUTH_FAILED on client; "Invalid verification code" in auth.log	23:55:36	[E08][E09]

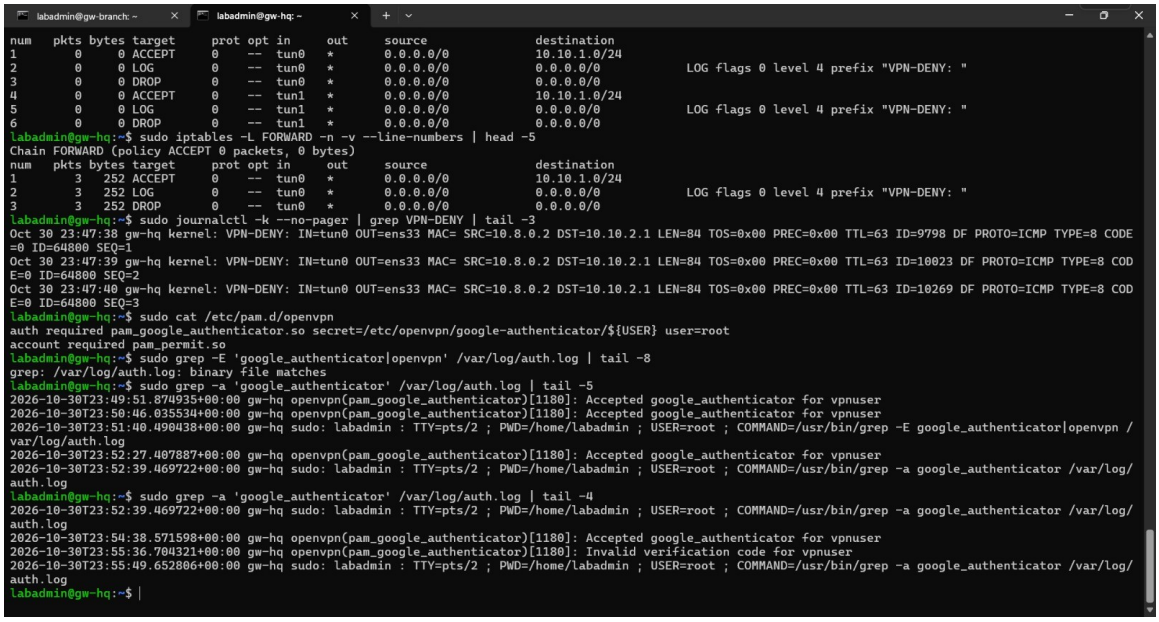


Figure 3. PAM configuration and auth.log with accepted and invalid codes [E09]

5 Authorization

Access is restricted by iptables FORWARD rules for tun0 and tun1: ACCEPT only to 10.10.1.0/24, everything else is logged with the prefix "VPN-DENY: " and dropped [E11]. From the client, 10.10.1.1 was reachable and 10.10.2.1 was blocked with 100% packet loss [E12]. Three VPN-DENY log lines (23:47:38 to 23:47:40 UTC) match the LOG/DROP counters of 3 packets, 252 bytes [E11].

Limits: the rules are network-based, not per user. The lab used one certificate and one account, so group- or role-based access was not demonstrated. Persistence of the rules after a reboot was not verified.

6 Integrity

The data channel uses AES-256-GCM, which authenticates every packet, and auth SHA256 is also configured [E10]. As an end-to-end test, a file was copied with scp through the tunnel and its SHA-256 matched on both ends: b2bc7d3f8b652d2ec96865b68ad8f80e22cca174abe1aed7889e242a747d590f [E17][E18]. SSH to gw-hq over the tunnel used password authentication; key-based SSH is recommended but not implemented.

7 Non-repudiation

Digital certificates authenticate the VPN endpoints, but the lab used a single client certificate and a single account. Because several people could share that identity, the lab does not demonstrate per-user accountability or non-repudiation. Achieving it would need per-user certificates, unique accounts, protected private keys (for example hardware-backed), and tamper-resistant central logs.

8 Implementation status

Category	Items

Implemented and verified	AES-256 on IPsec and OpenVPN [E01][E05]; certificate-based server and client authentication; TOTP accept and reject [E07] [E08][E09]; revocation blocks new connections [E23-E25]; SHA-256 file match [E17][E18]; network allow/deny [E11][E12]
Implemented but limited	Single-tier CA; one client certificate and one account; established-session cut-off untested; iptables persistence unverified; SSH password authentication over the tunnel
Recommended, not implemented	Two-tier PKI; per-user certificates; per-user access rules; key-based SSH; hardening: remove deprecated persist-key, set auth-nocache

Appendix: evidence cited

E01, E02, E03, E05, E07, E08, E09, E10, E11, E12, E17, E18, E23, E24, E25, E26.